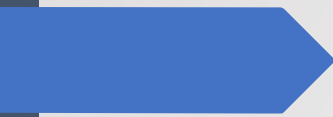




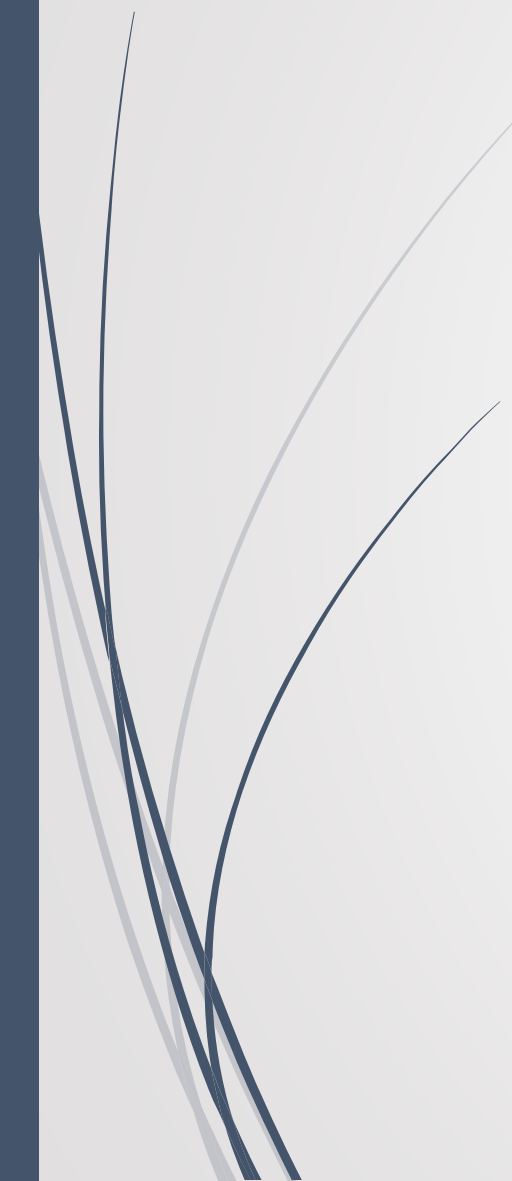
Réunion de restitution

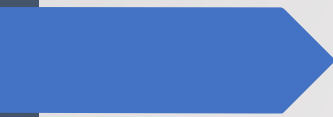
Pentest de la clinique de Frontignan

Walid Rhouma



Sommaire

- 
- 1) Contexte et périmètre
 - 2) Méthodologie
 - 3) Vulnérabilités
 - 4) Plan d'action



Contexte et périmètre

► Contexte :

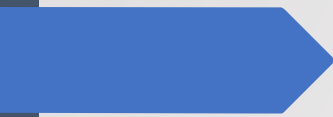
Date : Le 11/04/2025

Client : La clinique de Frontignan

La Clinique de Frontignan souhaite renforcer la sécurité de son système d'information en particulier son Active Directory.

Dans ce cadre, la Direction des Systèmes d'Information (DSI) a mandaté un audit de sécurité pour :

- Identifier les vulnérabilités de l'AD
- Evaluer les risques de compromission
- Proposer un plan correctif



Contexte et périmètre

► Périmètre:

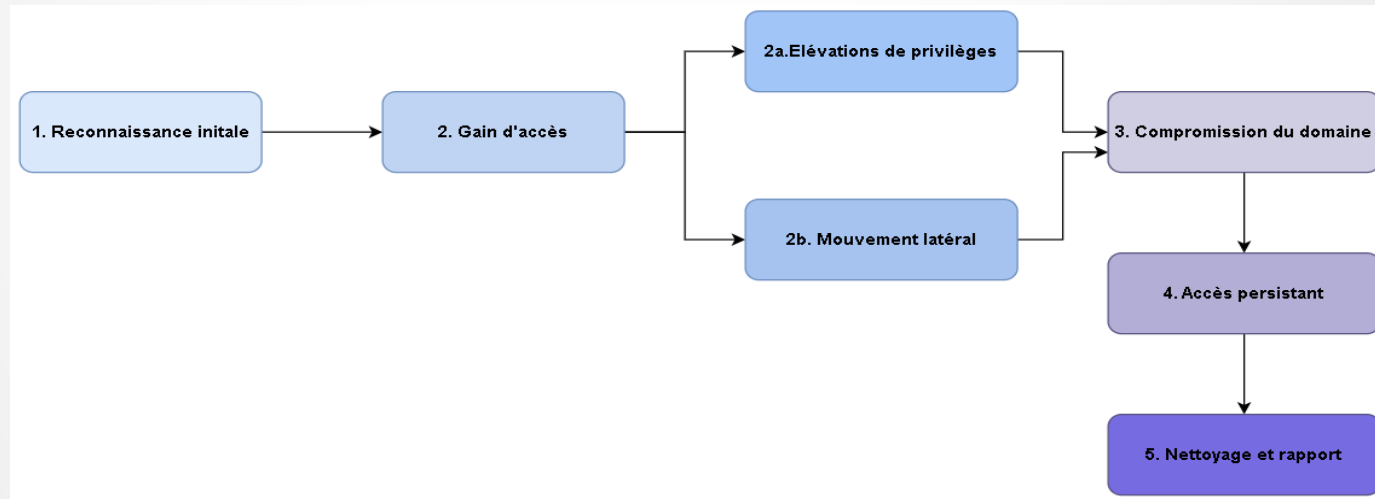
L'audit de sécurité porte sur l'environnement Active Directory de la clinique de Frontignan incluant :

- Les machines du réseau 10.10.10.0/24
- Les comptes utilisateurs, groupes et droits d'accès
- La stratégie de mot de passe
- Les protocoles réseau utilisés (LDAP,SMB,SSH,RDP,...)

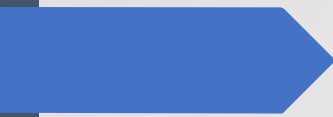
Les tests incluent une phase d'énumération, une tentative de compromission et une analyse des risques liés à la configuration actuelle.

Méthodologie

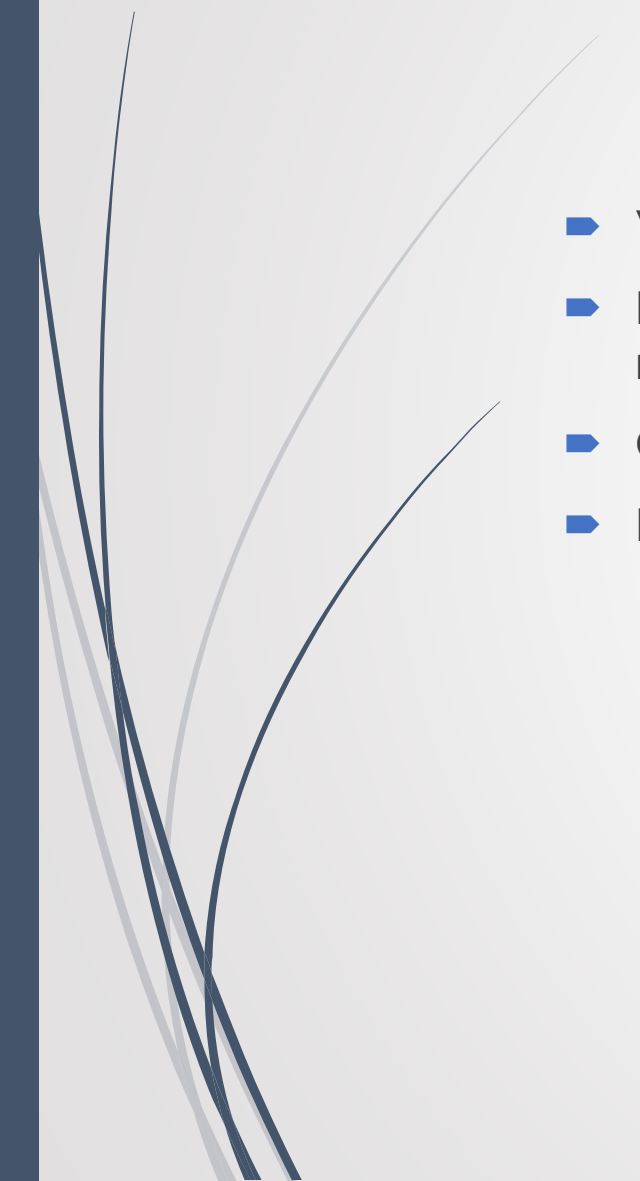
La méthodologie de ce test d'intrusion suit un cycle structuré, allant de la reconnaissance jusqu'à la compromission du domaine Active Directory. Elle inclut le gain d'accès initial, l'élévation de privilèges, le mouvement latéral, la mise en place d'un accès persistant, et se conclut par un nettoyage et la rédaction d'un rapport.



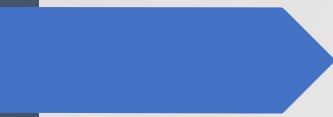
Chaque étape de ce cycle vise à reproduire les techniques utilisées par un attaquant réel afin d'évaluer concrètement le niveau de sécurité de l'AD.



Vulnérabilités



- ▀ V01 – Absence de segmentation réseau
- ▀ Description : La non-segmentation du réseau 10.10.10.0/24 facilite les mouvements latéraux en cas de compromission
- ▀ Criticité : Elevée
- ▀ Recommandations :
 - ✓ Mise en place de VLAN dédiés
 - ✓ Appliquer des ACL pour la gestion des flux inter-vlan
 - ✓ Définir des règles de pare-feu strictes

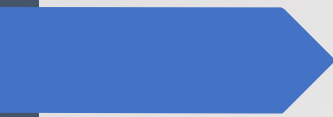


Vulnérabilités

- V02 – Absence de sécurisation des services LDAP
- Description : Le service LDAP est présent et accessible en clair, exposant des données sensibles (utilisateurs, groupes, machines) à des risques d'interception ou d'abus.
- Criticité : Moyenne
- Recommandations :
 - ✓ Désactiver le port 389 sur le contrôleur de domaine
 - ✓ Forcer LDAPS (port 636) avec un certificat TLS/SSL valide
 - ✓ Désactiver l'accès anonyme et restreindre les utilisateurs pouvant interroger l'annuaire
 - ✓ Modifier la configuration des applications utilisant LDAP pour utiliser LDAPS

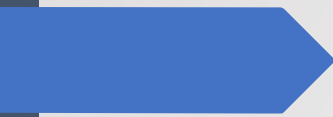
Vulnérabilités

- ▀ V03 – SMB signing désactivé sur certaines machines
- ▀ Description : L'absence de signature SMB permet des attaques de type NTLM relay facilitant la compromission sans mot de passe valide.
- ▀ Criticité : Moyenne
- ▀ Recommandations :
 - ✓ Activer le SMB Signing sur tous les hôtes du domaine via GPO
 - ✓ Vérifier son application avec la commande *gpresult*
 - ✓ Imposer la signature sur clients et serveurs pour bloquer les attaques MiTM (*Man-In-The-Middle*)



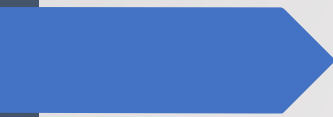
Vulnérabilités

- V04 – Mauvaise gestion des mots de passe
- Description : L'utilisation de mots de passe simples (ex : *test:test*) expose les comptes à des attaques automatisées de type password spraying.
- Criticité : Elevée
- Recommandations :
 - ✓ Appliquer une politique de mot de passe robuste (longueur > 12 caractères, complexité, expiration régulière)
 - ✓ Appliquer une expiration tous les 90 jours et bloquer la réutilisation des 5 derniers mots de passe
 - ✓ Interdire l'usage de mot de passe identique à l'identifiant

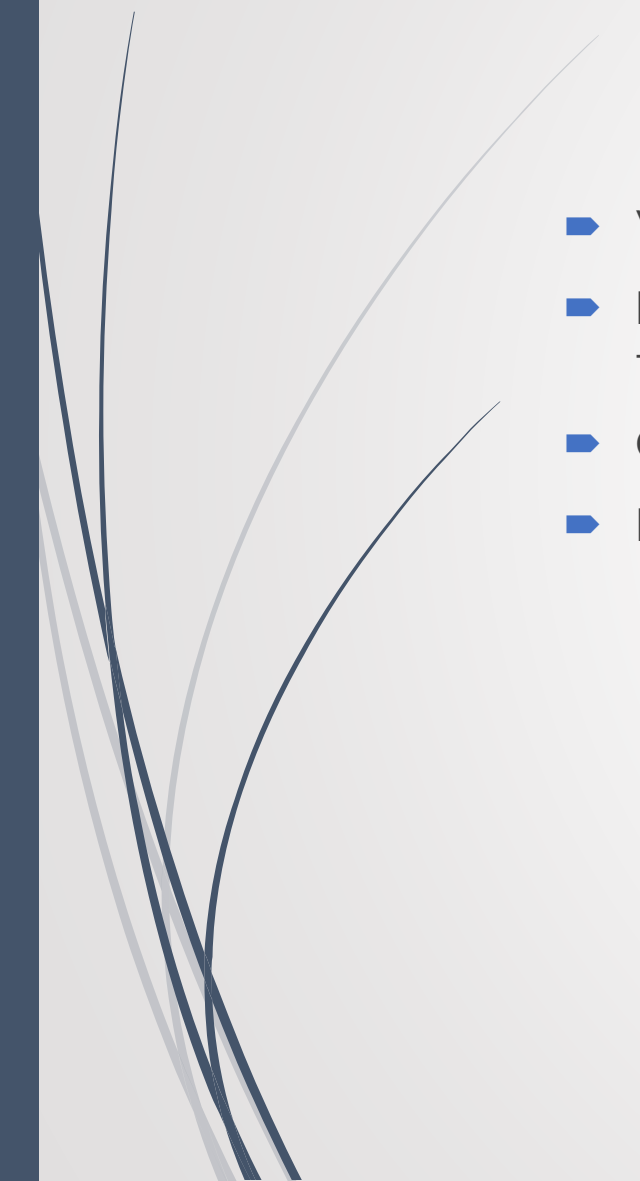


Vulnérabilités

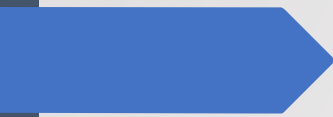
- ▀ V05 - Absence de verrouillage de comptes
- ▀ Description : Aucun verrouillage après plusieurs échecs de connexion, facilitant les attaques par brute-force ou password spraying.
- ▀ Criticité : Elevée
- ▀ Recommandations :
 - ✓ Activer le verrouillage après X tentatives échouées
 - ✓ Définir un déverrouillage automatique (ex : 30 min)
 - ✓ Surveiller les journaux pour repérer les comportements suspects



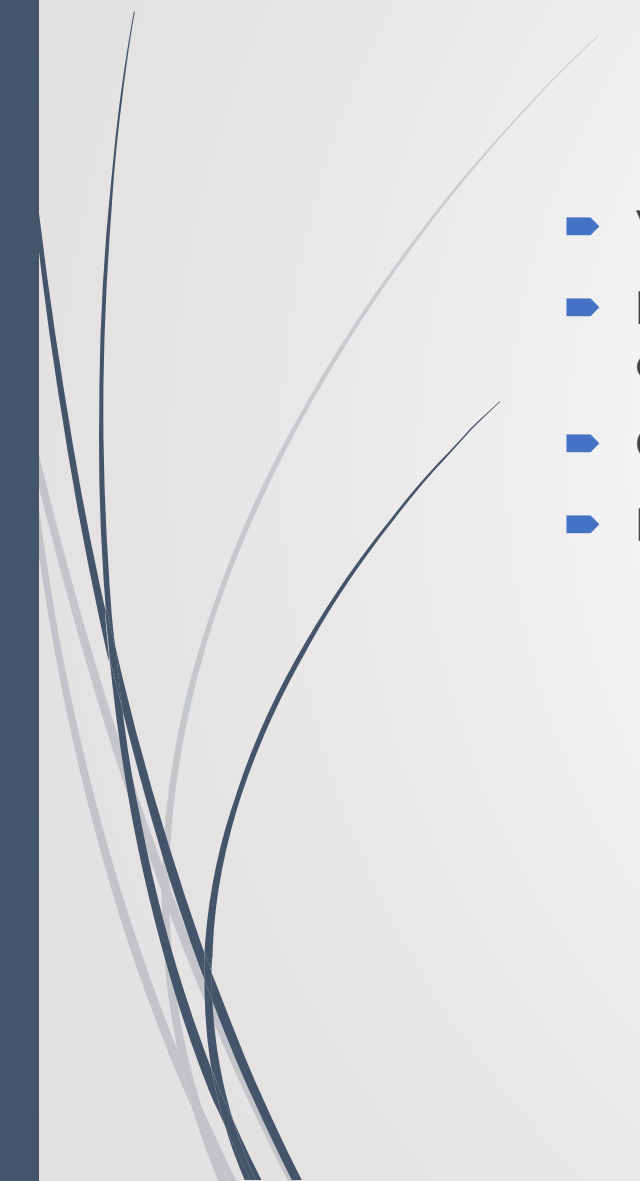
Vulnérabilités



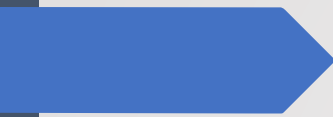
- V06 – Faiblesse des politiques de sécurité Active Directory
- Description : Absence de verrouillage de compte et politique de mot de passe trop laxiste (7 caractères, pas de complexité, expiration trop longue)
- Criticité : Elevée
- Recommandations :
 - ✓ Appliquer une politique de mots de passe et de verrouillage de comptes stricte
 - ✓ Révoquer les sessions actives des comptes à risque
 - ✓ Activer LAPS pour les administrateurs locaux



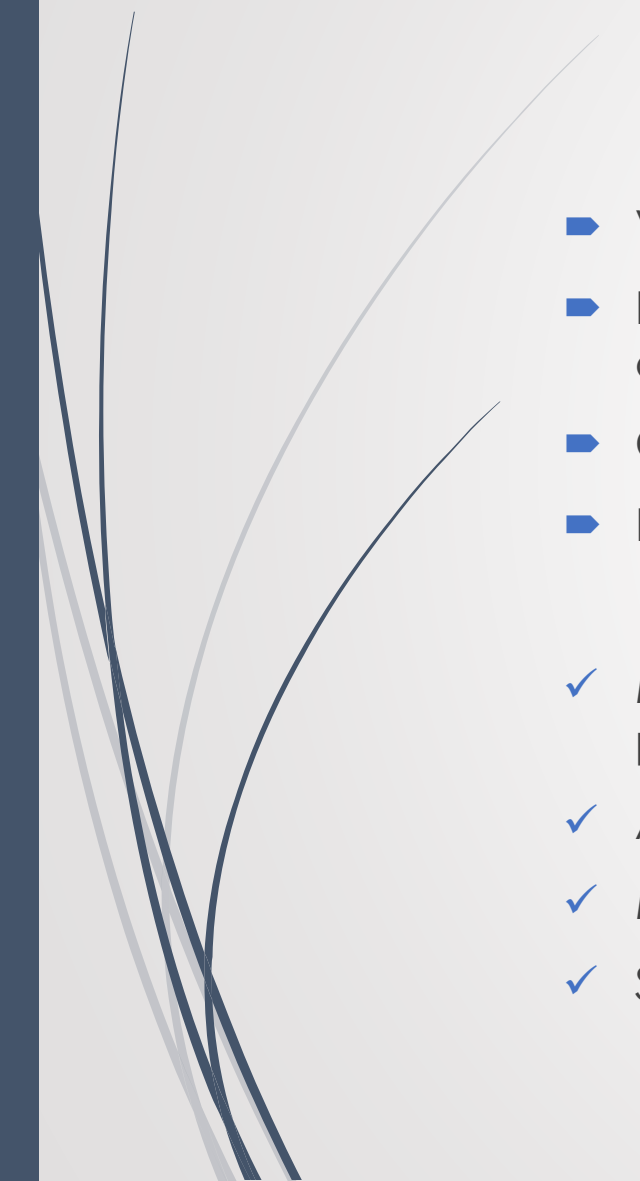
Vulnérabilités



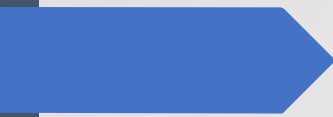
- ▀ V07 – Compte exposé avec mot de passe en clair
- ▀ Description : Le mot de passe du compte "amaillot" est visible en clair dans la description LDAP, ce qui constitue une faille critique.
- ▀ Criticité : Elevée
- ▀ Recommandations :
 - ✓ Supprimer immédiatement les mots de passe visibles dans les attributs LDAP
 - ✓ Vérifier l'ensemble des descriptions des objets Active Directory
 - ✓ Sensibiliser les administrateurs à ne jamais inscrire d'informations sensibles dans les champs descriptifs



Vulnérabilités



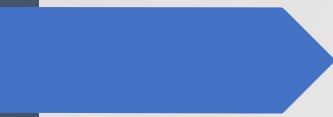
- ▀ V08 – Réutilisation de mots de passe
- ▀ Description : Le mot de passe "Support2021" est utilisé sur plusieurs comptes y compris des comptes à privilèges.
- ▀ Criticité : Elevée
- ▀ Recommandations :
 - ✓ Mettre en place une politique stricte interdisant la réutilisation des mots de passe
 - ✓ Appliquer une gestion individualisée et confidentielle des identifiants
 - ✓ Modifier immédiatement les mots de passe partagés ou compromis
 - ✓ Sensibiliser les utilisateurs aux risques liés à la réutilisation des mots de passe



Vulnérabilités

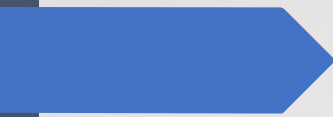


- V09 - Mauvaise gestion des mots de passe des comptes de service
- Description : Les comptes de service avec SPN utilisent des mots de passe faibles ou statiques, facilitant les attaques de type Kerberoasting.
- Criticité : Elevée
- Recommandations :
 - ✓ Utiliser des mots de passe robustes et longs pour tous les comptes de service et les modifier régulièrement
 - ✓ Restreindre les privilèges des comptes de service au strict minimum
 - ✓ Surveiller l'activité des SPN et détecter les extractions de tickets
 - ✓ Envisager l'usage de **gMSA** (Group Managed Service Accounts) pour automatiser la rotation des mots de passe



Plan d'action

- Application des correctifs de sécurité
- Mise en place d'une surveillance active via un SIEM
- Mise en place d'une gestion des accès privilégiés via PAM
- Sensibilisation aux bonnes pratiques et audits réguliers



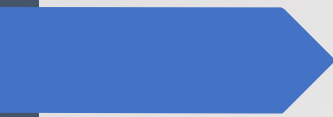
Plan d'action

■ Application des correctifs de sécurité

L'absence de correctifs expose les équipements à des vulnérabilités connues et exploitables par des attaquants. Les mises à jour régulières suppriment les failles de sécurité, renforcent la sécurité des systèmes et réduisent le risque de compromission.

Nos préconisations sont les suivantes :

- ✓ Vérifier les correctifs liés aux services SMB, LDAP et Kerberos
- ✓ Installer les dernières mises à jour Windows Server et client
- ✓ Déployer une solution de gestion des mises à jour comme WSUS ou SCCM



Plan d'action

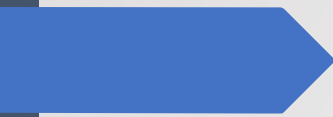
- Mise en place d'une surveillance active via un SIEM

L'absence de surveillance expose le réseau à des intrusions et comportements malveillants non détectés.

L'implémentation d'un SIEM permet d'identifier rapidement les activités suspectes et de répondre efficacement aux incidents de sécurité tout en optimisant l'analyse par la centralisation des logs.

Pour aller en ce sens il convient de :

- ✓ Installer un SIEM (Security Information and Event Management) comme Splunk
- ✓ Activer l'audit des tentatives de connexions échouées
- ✓ Configurer des alertes pour détecter des comportements anormaux (ex : connexions simultanées sur plusieurs machines)



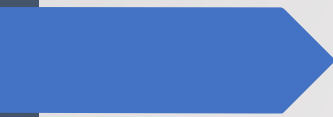
Plan d'action

- Mise en place d'une gestion des accès privilégiés via PAM

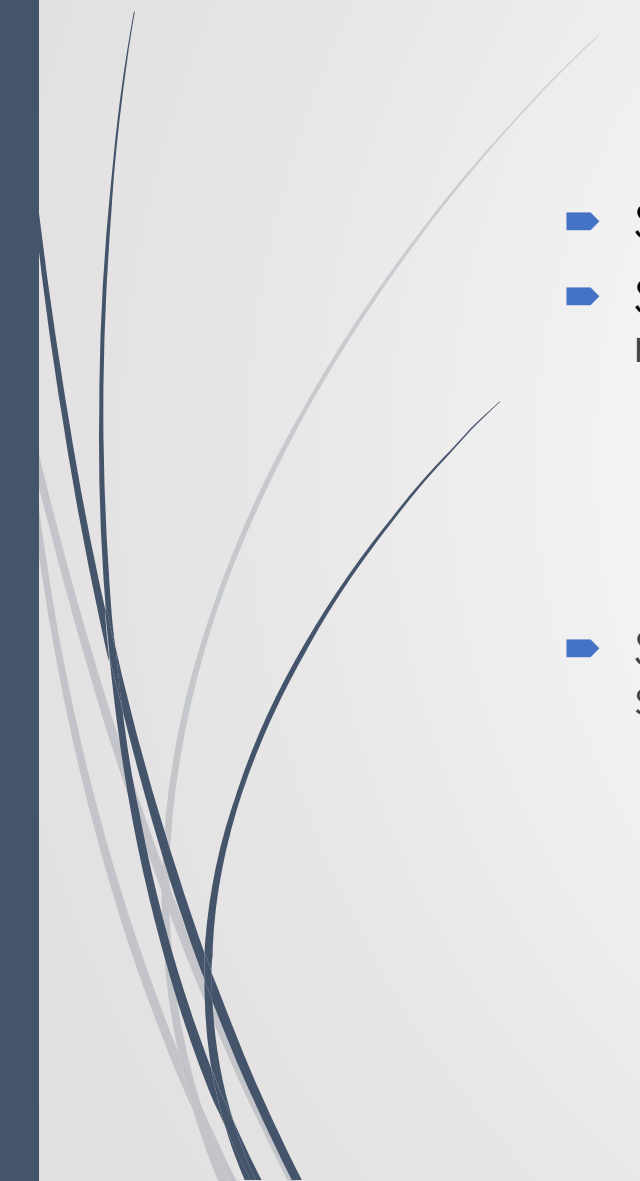
Les comptes à privilèges sont des cibles de choix pour les attaquants. L'absence de contrôle sur ces accès expose le système à des compromissions critiques. L'implémentation d'un PAM permet de réduire ces risques en restreignant et en surveillant l'utilisation de privilèges élevés.

Pour cela il convient de :

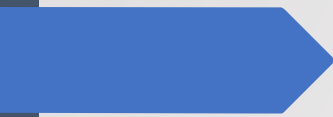
- ✓ Mettre en place un PAM (Privileged Access Managment) pour restreindre et surveiller les accès administrateurs
- ✓ Activer le principe de moindre privilège pour tous les comptes
- ✓ Limiter les connexions RDP uniquement aux comptes ayant un réel besoin



Plan d'action



- ▀ Sensibilisation aux bonnes pratiques et audits réguliers
- ▀ Sensibilisation des utilisateurs pour prévenir les erreurs humaines pour réduire les risques d'attaques ciblées
 - ✓ Former régulièrement sur les bonnes pratiques de cybersécurité
 - ✓ Sensibiliser aux risques de phishing et d'ingénierie sociale
 - ✓ Organiser des campagnes de test pour évaluer la vigilance
- ▀ Surveillance et audits réguliers afin d'identifier les vulnérabilités avant qu'elles ne soient exploitées
 - ✓ Réaliser des tests d'intrusion annuels pour détecter les failles
 - ✓ Contrôler les journaux d'audit et les configurations critiques
 - ✓ Mettre en place une détection automatisée des anomalies réseau



Conclusion



La cybersécurité est l'affaire de tous : une vigilance permanente et une sensibilisation continue permettront de garantir un environnement numérique plus sûr et performant.